

Manual 41 — Implementación Controlada de UK GDPR / Data Protection Act

****Línea base controlada:**** UK GDPR y Data Protection Act 2018 según enmendada por Data (Use and Access) Act 2025, sujeta a reverificación legislativa al release.

****Límite:**** texto legal, PECR cuando aplique, códigos/guidance del ICO, deberes sectoriales, contratos y prácticas internas permanecen como capas distintas.

****Regla de release:**** reverificar legislación vigente y material de implementación del ICO al congelar el candidato.

Chapter 01 — Propósito, alcance y jerarquía de fuentes

Defina jerarquía legal controlada, método de aplicabilidad, owners, change watch e índice de evidencia. No presente guidance del regulador como texto legal.

Chapter 02 — Aplicabilidad y alcance territorial

Determine aplicabilidad considerando establecimiento, targeting, monitoring, exenciones y hechos transfronterizos. Registre fundamentos de inclusión/exclusión.

Chapter 03 — Roles controller, processor y joint controller

Asigne roles según propósitos, medios, instrucciones y relaciones reales. Mantenga assessments, contratos, arreglos conjuntos y triggers de revisión.

Chapter 04 — Accountability y gobernanza

Asigne responsabilidades ejecutivas, DPO/privacy, legal, security, records, procurement, product, HR y operaciones. Mantenga políticas, decisiones, riesgos, issues y management review.

Chapter 05 — Records of processing e inventario

Mantenga registros de procesamiento, sistemas, propósitos, categorías, data subjects, recipients, transfers, retention, lawful bases, medidas y owners.

Chapter 06 — Lawful bases

Exija decisión documentada antes de procesar. Distinga contract, legal obligation, vital interests, public task, legitimate interests, consent y otras condiciones aplicables.

Chapter 07 — Legitimate interests y recognized legitimate interests

Documente la ruta aplicable, propósito, necesidad, balancing o condiciones legales, safeguards, transparency, objections y triggers. No combine rutas legales distintas.

Chapter 08 — Gobernanza del consentimiento

Cuando se use consent, asegure validez contextual y mantenga captura, granularidad, evidencia, withdrawal, refresh y suppression downstream.

Chapter 09 — Transparencia y privacy information

Proporcione información clara y accesible sobre processing, purposes, bases, recipients, transfers, retention, rights, complaints y automated processing relevante.

Chapter 10 — Purpose limitation y data minimization

Limite recolección/uso a propósitos documentados y datos apropiados. Governe secondary use, compatibility analysis y excepciones.

Chapter 11 — Accuracy y data quality

Defina controles de calidad, correction, source reliability, propagación de cambios y monitoring proporcional al riesgo.

Chapter 12 — Retention, deletion y archival

Mantenga reglas basadas en requisitos legales, regulatorios, contractuales, records, litigation y operativos. Ejecute deletion defensible y excepciones controladas.

Chapter 13 — Security of processing

Implemente medidas administrativas, técnicas y organizativas proporcionales al riesgo: identity/access, encryption, resilience, logging, vulnerability management, recovery y assurance.

Chapter 14 — Processor y contract governance

Selecione processors mediante due diligence y mantenga instrucciones, confidentiality, security, subprocessors, assistance, deletion/return, audit e incident obligations.

Chapter 15 — International transfers

Identifique restricted transfers y documente mecanismo, assessment, safeguards, supplementary measures, exceptions, onward controls y monitoring aplicables.

Chapter 16 — Subject access requests

Controle intake, identity/authority, search, exemptions, third-party balancing, response, secure delivery, timing, escalation y evidence retention.

Chapter 17 — Rectification, erasure y restriction

Defina workflows para correction, deletion y restriction, incluyendo recipient notification, exceptions, legal holds, ejecución técnica y closure evidence.

Chapter 18 — Objection rights

Evalúe objections según processing basis/context, incluyendo direct marketing. Mantenga decisiones, suppression, escalation e implementación downstream.

Chapter 19 — Data portability

Determine cuándo aplica y entregue datos en formato estructurado apropiado con controles seguros. Documente exclusions y delivery evidence.

Chapter 20 — Automated decision-making y profiling

Identifique procesos solely automated/materialmente significativos, condiciones legales/safeguards, transparency, human intervention, challenge, testing y monitoring.

Chapter 21 — Children y personas que requieren manejo especial

Aplique controles apropiados de edad, capacidad, vulnerabilidad, service/context, transparency, authority, risk y safeguarding sin asumir un umbral universal.

Chapter 22 — Special-category y criminal-offence data

Documente condiciones aplicables, requisitos DPA/Schedule, policy documents donde corresponda, access restrictions, minimization, retention y heightened assurance.

Chapter 23 — DPIAs y high-risk processing

Screening antes de launch/cambio material. Mantenga scope, necessity/proportionality, risks, measures, residual risk, consultation, approval y review triggers.

Chapter 24 — Personal-data breach response

Integre detection, containment, evidence preservation, risk assessment, notification decisions, communications, processor coordination, remediation y breach records.

Chapter 25 — Complaints y regulator engagement

Mantenga intake, investigation, response, escalation, corrective action, regulator correspondence, legal review y preservación de evidencia.

Chapter 26 — PECR y electronic communications boundary

Evalúe cookies, tracking, direct marketing y communications separadamente de UK GDPR. Mantenga consent/exemption logic, settings, suppression y change watch.

Chapter 27 — Research, statistics y public-interest overlays

Documente bases, safeguards, compatibility, minimization, access, transparency, exemptions, governance y disclosure limits aplicables.

Chapter 28 — Training y role competence

Entregue training basado en rol para handlers, rights teams, engineering, marketing, HR, procurement, security, executives e incident personnel. Mantenga completion/competency evidence.

Chapter 29 — Assurance y audit

Pruebe notices, lawful bases, rights, contracts, transfers, DPIAs, security, breaches, retention y automated processing con muestras basadas en riesgo. Cierre findings con evidencia.

Chapter 30 — Métricas y management review

Monitoree rights timeliness, complaints, breaches, DPIA backlog, transfers, processor findings, retention exceptions, training, remediation y legal change. Registre decisiones.

Chapter 31 — Localización, provenance y evidencia de release

Congele candidatos EN/es-419/pt-BR; vincule DOCX/PDF a SHA-256 y preserve source-version, structure, parity, accessibility, render, workflow-security y staging evidence.

Chapter 32 — Roadmap y reverificación al release

Implemente applicability/inventory; governance/bases; transparency/rights; processors/transfers; security/breaches; high-risk/automated processing; assurance/improvement. Antes de publicar reverifique UK GDPR, DPA 2018, estado DUAA 2025, PECR cuando se reclame e ICO aplicable. Publicación secuencial después del Manual 40.